

# ifotoset Architecture Blueprint

Fullstack Laravel Admin & Studio Panels • Finalized Decisions & Implementation

## Roadmap

### Architectural Consensus

A high-performance Blade + Alpine.js + Tailwind CSS fullstack monolith adhering to clean separation: **HTTP Layer → Dedicated Middleware → Thin Domain Controllers → Domain Actions (Mutations) & Query Classes (Reads) → Models / DB / Redis / B2.**

## 1. Core Architectural Pillars

Blade / Alpine (Client UI)



HTTP Route Layer (Named & Grouped)



Dedicated Middleware (AdminMiddleware & Auth)



Thin Domain Controllers (Orchestration only)



Query Classes (Optimized Reads)    Actions (Domain Mutations)    Policies (Resource Ownership)



- Append-only Audit Logging

- Last-Admin Safeguards

- Events & Background Queues

## 2. Seven Non-Negotiable Production Safeguards

| Safeguard                                 | Implementation Specification                                                                                                                                                                                                                                                                              |
|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>1. Authoritative AdminMiddleware</b>   | Guards all <code>/admin/*</code> routes at HTTP entry. Intercepts unauthorized sessions and redirects to <code>route('studio.dashboard')</code> with a flash error. Never relies on client-side UI hiding.                                                                                                |
| <b>2. Tenant Isolation &amp; Policies</b> | Queries and Actions strictly receive the authenticated photographer (e.g. <code>StudioClientsQuery::for(\$user)</code> , <code>UpdateClient::execute(\$user, \$client, \$data)</code> ) backed by Laravel Resource Policies. Tested via cross-tenant ID manipulation.                                     |
| <b>3. Last-Admin Protection</b>           | Enforced inside a database transaction with row-locking. Rejects demotion, suspension, or deletion if active admins count $\leq 1$ . Admins are strictly prevented from demoting/deleting themselves via UI.                                                                                              |
| <b>4. Append-Only Audit Trail</b>         | <code>admin_audit_logs</code> table records every administrative intervention (role change, suspension, gallery takedown, moderation, SMTP updates) atomically within the same DB transaction as the mutation.                                                                                            |
| <b>5. Encrypted Secret Handling</b>       | SMTP passwords encrypted using <code>Crypt::encryptString()</code> in <code>SystemSetting</code> . Blade templates only receive <code>has_password: true</code> and masked placeholders ( <code>.....</code> ). Test endpoint is <code>POST /admin/settings/smtp/test</code> with rate limiting and CSRF. |
| <b>6. Idempotent Destructive Ops</b>      | Gallery purge, account suspension, and package deactivation are designed to be idempotent and safe against accidental double-execution. Package removal uses soft-deactivation ( <code>is_active = false</code> ) to preserve booking history.                                                            |
| <b>7. Intended URL &amp;</b>              | Login, registration, and email verification seamlessly honor <code>redirect()-</code>                                                                                                                                                                                                                     |

| Safeguard        | Implementation Specification                                                                                                                                                             |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Canonical Routes | <code>&gt;intended()</code> with role-aware fallbacks. The <code>/g/{slug}</code> shortlink resolves canonical owner/slug while letting existing gallery access-control enforce privacy. |

### 3. Detailed Domain & Controller Boundaries

---

#### Studio Suite (Photographers)

- **Dashboard (Studio\DashboardController):** Driven by `StudioDashboardQuery` for bounded, indexed metrics (storage quota, pending bookings, active galleries, upcoming sessions).
- **Galleries (Studio\GalleryController):** Status tabs (All, Public, PIN, Private), direct B2 upload manager, cover selector, watermarking settings.
- **Bookings (Studio\BookingController):** Status pipeline (Pending → Confirmed → Completed / Cancelled), deposit payment status, client details modal.
- **Availability (Studio\AvailabilityController):** Weekly 7-day recurring schedule, photographer timezone, slot duration (15/30/60m), date-specific exceptions, and blackout time blocks.
- **Clients CRM (Studio\ClientController):** `StudioClientsQuery` with search, tags, booking history, lifetime spend, Add/Edit modals, and client detail drawer.
- **Packages (Studio\PackageController):** Photography offerings, deliverables checklist, deposit rules (fixed/percentage), and safe deactivation toggle.
- **Analytics (Studio\AnalyticsController):** `StudioAnalyticsQuery` with period selector (7d/30d/90d), SVG views trend chart, top galleries leaderboard, and traffic acquisition breakdown.
- **Settings (Studio\SettingsController):** Profile info, bio, avatar upload, password change (using standard Laravel hash primitives), and notification preferences.
- **Trash (Studio\TrashController):** Soft-deleted galleries, individual restore/purge, and bulk "Empty Trash" with double-confirmation dialog.

#### Admin Suite (Platform Superadmins)

- **Platform Overview (Admin\DashboardController):** Platform KPIs (photographers, galleries,

storage, revenue), background queue health, recent tenant registrations.

- **User Management (Admin\UserController):** Searchable directory, active/suspended toggle, role assignment (backed by Last-Admin guard and audit logs).
- **Gallery Moderation (Admin\GalleryController & Admin\ModerationController):** Platform-wide gallery index, flagged content review, priority indicators, approve and takedown actions.
- **Payments (Admin\PaymentController):** Aggregates over real Payment records (PawaPay MTN MoMo, subscriptions, booking deposits), status filters, financial volume metrics.
- **Platform Analytics (Admin\AnalyticsController):** User growth curve, gallery distribution categories, top studio rankings.
- **Support Tickets (Admin\SupportController):** Inquiry queue, priority tags (Urgent, High, Medium, Low), status updates (Open, In Progress, Resolved).
- **Settings & SMTP (Admin\SettingsController):** Encrypted SMTP configuration, live POST test email sender, and general platform parameters.

#### 4. Complete 7-Phase Execution Plan

| Phase   | Deliverables                       | Key Security & Functional Milestones                                                                                                            |
|---------|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| Phase 1 | Auth, Middleware, Routes & Layouts | Implement AdminMiddleware, role-aware login with intended(), canonical route names, global Alpine toast system, and shared Blade UI components. |
| Phase 2 | Audit Infrastructure & Safeguards  | admin_audit_logs migration/model, atomic AdminAuditLog::record(), and transaction-safe Last-Admin guard rules.                                  |
| Phase 3 | Studio Core & Safe Purge           | Refactor Studio Dashboard to StudioDashboardQuery, enhance Booking status transitions, and implement idempotent gallery purge.                  |
| Phase 4 | Studio Business Suite              | Implement Availability (schedule, exceptions, blocks), Clients CRM, Packages (with safe deactivation), Studio Analytics, and Settings tabs.     |

| Phase   | Deliverables                            | Key Security & Functional Milestones                                                                                                                                                         |
|---------|-----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Phase 5 | Admin Core                              | Admin Dashboard query, User directory with role/status mutations (audited & protected), and Gallery moderation actions.                                                                      |
| Phase 6 | Admin Extensions                        | Payments aggregation query, Platform Analytics query, Moderation queue, Support ticket management, and Encrypted SMTP panel with live test tool.                                             |
| Phase 7 | Security, Isolation & Route Smoke Tests | Suite of tests: <code>AdminSecurityTest</code> , <code>StudioIsolationTest</code> (UUID cross-tenant tampering), <code>RouteSmokeTest</code> , Vite asset bundle verification, and final QA. |